

ISO 27001 Incident Management Report SQL Injection Vulnerability – DVWA

Introduction

This report documents the identification and exploitation of an SQL Injection vulnerability in the Damn Vulnerable Web Application (DVWA). The test was performed in a controlled laboratory environment as part of a cybersecurity training exercise. The objective was to demonstrate how improper input validation can allow attackers to manipulate database queries and gain unauthorized access to sensitive information.

Incident Description

During the security assessment of DVWA, a vulnerability was identified in the SQL Injection module. The application fails to properly validate user input in the "User ID" field, allowing malicious SQL code to be injected into the query executed by the database.

SQL Injection Method Used

To demonstrate the vulnerability, the following SQL payload was entered in the User ID field: `1' OR '1'='1`. This payload modifies the SQL query executed by the application and forces the database to return all records from the users table instead of a single user.

Incident Impact

- Unauthorized access to user information stored in the database.
- Enumeration of multiple user accounts.
- Potential exposure of password hashes and other sensitive data.
- Compromise of confidentiality and integrity of the system.

Recommendations

- Implement strict input validation for all user inputs.
- Use prepared statements and parameterized queries.
- Deploy a Web Application Firewall (WAF) to detect malicious queries.
- Conduct regular penetration testing and security assessments.
- Train developers in secure coding practices.

Conclusion

The successful exploitation of the SQL Injection vulnerability in DVWA highlights the importance of secure coding practices and proper input validation. Organizations must implement robust security controls and continuous security testing to protect applications and sensitive data.